

ITU-MiniTwit - Group e - Report

Frederik Hørup , Marie Johansen , Nikolej Lundquist , Sara Bagger , Vitus Brodersen <>

May 21, 2026

Contents

1	Introduction	1
2	System	1
2.1	Architecture and Design	1
2.2	Dependencies	1
2.3	System States	1
3	Process	2
3.1	CI/CD	2
3.2	Monitoring	2
3.3	Logging	3
3.4	Security	3
3.5	Availability and Scaling	4
4	Reflection	4
5	Use of Generative AI	4
	References	4

1 Introduction

Authors:

2 System

2.1 Architecture and Design

Authors:

2.2 Dependencies

Authors:

2.3 System States

Authors:

Figure 1: CI-CD pipeline

3 Process

3.1 CI/CD

Authors: Vitus, Frederik, Nikolej

The CI/CD process is based on GitHub Actions workflows that run on the `main` branch or on a scheduled timer. The MiniTwit repository currently uses the following active workflows to complete CI/CD:

- **static-analysis** — runs on push and pull request events for `main`. It performs:
 - Dockerfile linting with Hadolint against `Dockerfile-MiniTwit`.
 - .NET setup and tool restore.
 - C# formatting validation with `dotnet csharpier check ..`
 - CodeQL initialization for C#.
 - Dependency restore and a strict Roslyn build with `TreatWarningsAsErrors=true`.
 - CodeQL analysis to surface static security issues.
 - Docker Scout scanning for critical vulnerabilities on the DockerHub image.
- **build-and-test** — runs on push and pull request events for `main`. It restores dependencies, performs a clean build, and runs the test suite.
- **SonarCloud & Codacy** — provides external static analysis, code smell detection, and quality gating on Pull Requests.
- **Deploy to Staging VM** — runs on push and pull request events for `main` after the primary checks pass. Builds and pushes the Docker images and deploys them to the DigitalOcean staging Droplet.
- **Deploy To DO** — runs on pushes to `main` and can also be triggered manually. It builds and pushes the Docker images and deploys them to the DigitalOcean production Droplets.
- **automatic-weekly-release** — runs on schedule every Tuesday at 08:00 UTC and can be started manually. It builds the project, runs tests, packages release artifacts, and creates a GitHub release.

CI-CD pipeline

3.2 Monitoring

Authors: Marie, Sara, Nikolej

Monitoring is set up using Prometheus (“Prometheus Documentation” 2026) and Grafana (“Grafana Documentation” 2026) for visualizing and querying metrics, by adding the `app.MapMetrics()`; and `app.UseHttpMetrics()`; middleware the pipeline. `app.MapMetrics()`; exposes the HTTP endpoint for Prometheus to scrape and `app.UseHttpMetrics()`; collects Prometheus metrics for processed HTTP requests (from documentation of `UseHttpMetrics`).

The setup is pull-based as the application exposes metrics which are then pulled by Prometheus.

In Grafana, the monitoring has been split up into two dashboards; application metrics and infrastructure metrics (see video Monitoring Dashboards). Application metrics focuses mainly on request rates. It displays CPU usage in seconds, the amount of HTTP request received, and statistics on different types of requests. Infrastructure metrics focus on the server side and display dashboards containing information about: memory usage, CPU usage and process uptime.

The application’s monitoring is at the reactive level (Turnbull 2014), as only a limited set of primarily operational dashboards are provided, with the main focus being on measuring availability. The monitoring does not supply data to measure user experience or data to benefit the business side.

There are many ways monitoring could be improved. For one, database monitoring would have been especially beneficial both for the operational side and to provide metrics for the business side e.g. number of users in

the system.

Lastly, the monitoring dashboards provided by DigitalOcean to monitor the Droplets has been regularly used.

3.3 Logging

Authors: Nikolej

The system uses a minimal push-based logging stack utilizing Alloy (“Grafana Alloy Documentation” 2026), Loki (“Grafana Loki Documentation” 2026) and Grafana (“Grafana Documentation” 2026), focusing on aggregation and visualization rather than analysis. The Grafana-Loki stack was primarily chosen because it is cheap to run and for its native support for Grafana, which the existing monitoring system was already using.

Alloy collects logs from running Docker containers through the Docker socket `host = unix:///var/run/docker.sock`, and populates them with metadata like labels before forwarding to Loki for storage. Lastly, the logs are queried by Grafana and presented visually.

Our chosen focus on aggregation and visualization is accomplished by grouping logs by containers in Grafana. The default Grafana Logs Drilldown page is more than sufficient for this purpose, hence there are no custom dashboards.

By providing a centralized view of all system logs, this setup improves observability significantly, allowing easier searching and faster response in case of errors.

Even though the logging setup was used in a limited capacity during development, it proved to be especially useful if for instance the simulation suddenly reports failed requests. The MiniTwit container logs include errors, HTTP requests and database queries, which allows us to pinpoint the problem quickly. Or if the monitoring setup indicates something unexpected, the aggregated logging platform allows us to ascertain whether it is a problem with the monitoring stack or the application itself.

3.4 Security

Authors: Sara

We applied several security hardening measures to our system across infrastructure, network, CI/CD, and container configuration.

Reverse proxy/TLS. First, we deployed a Nginx reverse proxy to the application and enabled HTTPS using TLS certificates. The reverse proxy terminates incoming HTTPS traffic and forwards requests internally to the application containers. This improves security by encrypting communication between clients and the server and by reducing direct exposure of the application itself. We used Let’s Encrypt certificates together with automatic renewal through Certbot to avoid manual certificate management and ensure continued HTTPS availability.

CI/CD. In the CI/CD pipeline, we integrated automated security analysis tools to support a shift-left security approach, where vulnerabilities are detected before deployment. We added GitHub CodeQL analysis to statically scan the application source code for known security vulnerabilities and insecure coding patterns. Additionally, we integrated Docker Scout to scan container images for known common vulnerabilities and exposures and vulnerable dependencies. The pipeline was configured to fail on critical vulnerabilities, preventing insecure images from being deployed automatically.

Docker hardened images. We also hardened our Docker environment by switching several production services to Docker Hardened Images (DHI). Specifically, we replaced standard Grafana, Prometheus, and ASP.NET images with hardened variants from dhi.io. These images are designed to reduce attack surfaces by minimizing unnecessary packages and dependencies.

Container execution. Beyond changing base images, we further hardened container execution. For example, Grafana was configured to run as a non-root user instead of running with root privileges.

We also introduced initialization steps to ensure correct permissions on mounted volumes without granting unnecessary privileges to the running application containers.

A key lesson from the course was that security should not rely on a single mechanism. Therefore, our approach combined multiple layers of protection: encrypted communication through TLS, restricted network access through firewalls, automated vulnerability scanning in CI/CD, hardened container images, and safer runtime configurations. This follows a defense-in-depth strategy, where multiple independent security mechanisms reduce the likelihood that a single vulnerability compromises the entire system.

3.5 Availability and Scaling

Authors: Frederik, Nikolej, Sara, Marie

To increase the availability of the system, a simple load balancing setup was implemented (see the diagram in the deployment section). One primary load balancer initially handles all traffic, but is automatically replaced by a secondary backup in case of failure. Additionally, the system was scaled to run two application instances simultaneously on separate DigitalOcean Droplets.

This could be improved by running at least 2 instances of the application on each of the two Droplets, and subsequently implementing an update strategy in the CI/CD pipeline. For instance, the blue-green upgrade strategy.

4 Reflection

Authors:

5 Use of Generative AI

Authors: Nikolej, Sara

During the development of this project we used ChatGPT in three main ways:

Debugging. When encountering unexpected bugs and unclear error messages, we often consulted ChatGPT about possible causes and fixes. While it rarely solved issues entirely on its own, it frequently helped narrow down the problem space and suggested relevant debugging strategies.

Research. This course presents challenges involving numerous technologies, many of which we were unfamiliar with, including monitoring tools, docker and load balancing. ChatGPT was used to summarize lengthy documentation, explain unfamiliar concepts, and provide concrete guides tailored to our situation.

Generating boilerplate / configurations. ChatGPT was also used for simple, repetitive tasks such as generating boilerplate code or writing Github Actions Workflow files. For example, the `build-report.yml` workflow, that converts the markdown source into a pdf.

The use of AI has made these tasks easier, spared us many frustrations during troubleshooting and saved considerable time during development. At the same time, we met certain limitations when using AI. Suggested fixes sometimes appeared plausible while being incorrect or incompatible with our setup. Additionally, relying on AI summaries may have reduced some of the deeper understanding that can come from manually reading documentation or solving problems independently, like spending hours solving a tiny bug. As a result, we found that generative AI was most useful as a supporting tool rather than a replacement for critical thinking, testing, and technical understanding.

References

- “Grafana Alloy Documentation.” 2026. 2026. <https://grafana.com/docs/alloy/latest/>.
- “Grafana Documentation.” 2026. 2026. <https://grafana.com/docs/>.
- “Grafana Loki Documentation.” 2026. 2026. <https://grafana.com/docs/loki/latest/>.
- “Prometheus Documentation.” 2026. 2026. <https://prometheus.io/docs/introduction/overview/>.
- Turnbull, James. 2014. *The Art of Monitoring*. James Turnbull.